

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	3
1 ОЗНАКОМЛЕНИЕ С МАТЕРИАЛОМ.....	3
2 ОПИСАНИЕ БАЗ ДАННЫХ УГРОЗ.....	3
2.1 ФСТЭК.....	3
2.2 NVD.....	4
2.3 Vulners.....	5
2.4 JVN.....	5
2.5 Exploit-db.....	6
3 ОЦЕНКА УЯЗВИМОСТИ КАЛЬКУЛЯТОРОМ CVSS.....	7
3.1 Оценка по базовым метрикам.....	7
3.2 Оценка по временным метрикам.....	8
3.3 Оценка по контекстным метрикам.....	9
3.4 Отличия CVSS 3.1 от CVSS 4.0.....	10
ЗАКЛЮЧЕНИЕ.....	11
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....	11

ВВЕДЕНИЕ

Цель работы — получить знания и навыки работы с различными базами данных угроз и уязвимостей. Работа индивидуальная.

Для достижения указанной цели необходимо решение следующих задач:

- проанализировать пять выбранных баз данных угроз и уязвимостей и дать каждой развёрнутое описание;
- провести работу с калькулятором CVSS, выполнив оценку уязвимостей по трём группам метрик: базовым, временным и контекстным;
- выяснить, в чём отличие CVSS 4.0, от предыдущих метрик.

1 ОЗНАКОМЛЕНИЕ С МАТЕРИАЛОМ

Обязательный материал для ознакомления:

- <https://habr.com/ru/company/pt/blog/266485/>;
- <https://habr.com/ru/company/ic-dv/blog/453756/>;
- <https://xakep.ru/2009/05/15/48221/#toc01>;
- <https://habr.com/ru/company/xakep/blog/305262/>;
- <https://habr.com/ru/companies/tomhunter/articles/754812/>.

2 ОПИСАНИЕ БАЗ ДАННЫХ УГРОЗ

2.1 ФСТЭК

ФСТЭК — это ключевой государственный регулятор в ИБ, у них есть своя БДУ. Угрозы там сортируются по источнику угрозы (внешний/внутренний, низкий/средний/высокий) и по последствиям (конфиденциальность/целостность/доступность), ещё в карточке есть описание и объект воздействия, всего в базе 227 угроз (рисунок 1).

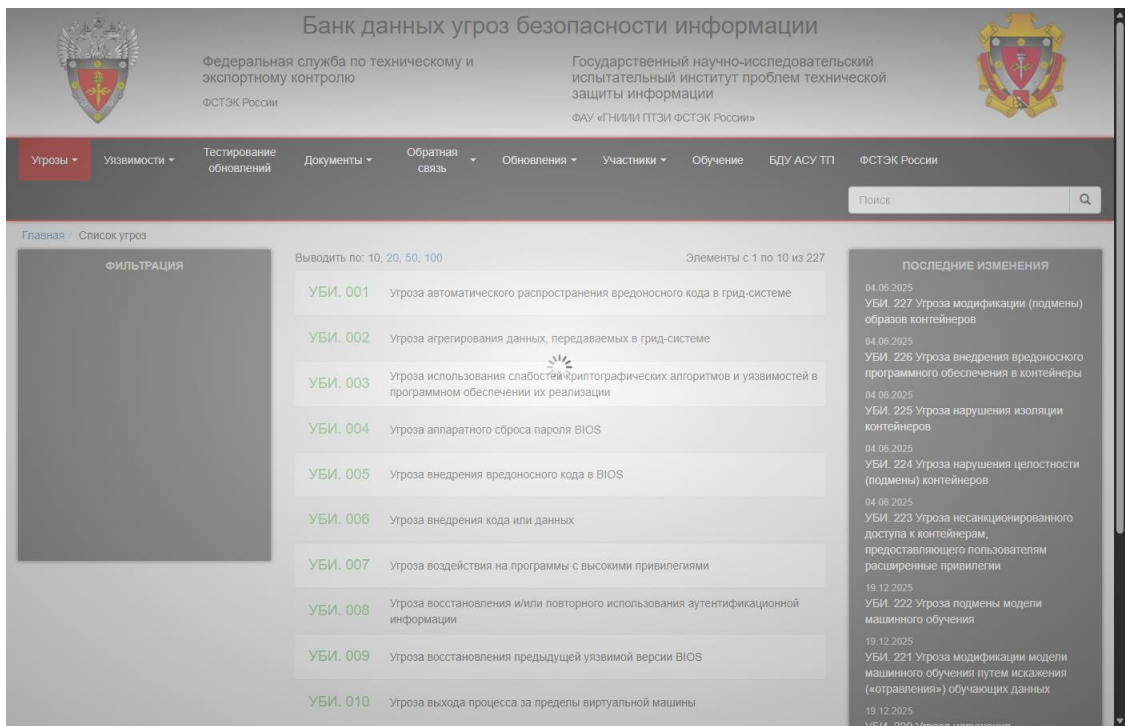


Рисунок 1 – БДУ ФСТЭК

2.2 NVD

NVD (National Vulnerability Database) — это список известных уязвимостей, у каждой есть CVE ID. В записи обычно лежат описание, ссылки на патчи и оценка CVSS. База общая, не сосредоточена на уязвимостях одного рода, одна из самых популярных (рисунок 2).

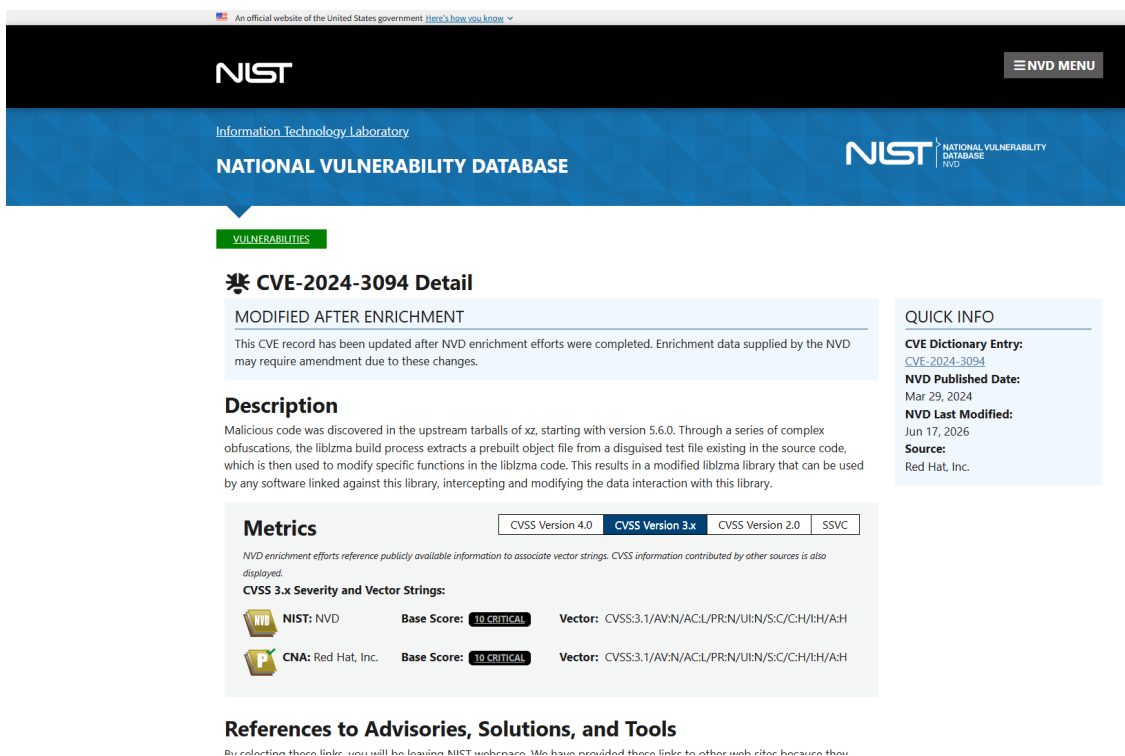


Рисунок 2 – Домашняя страница NVD / карточка CVE

2.3 Vulners

Vulners — это большая база ИБ контента, она всё время обновляется. Искать там можно как в обычном поисковике: уязвимости, эксплойты, патчи, bug bounty. Он тянет другие БД, бюлетени вендоров, Exploit-db, плагины для детекта. Результаты можно фильтровать по CVSS, дате, типу бюллетеня (рисунок 3).

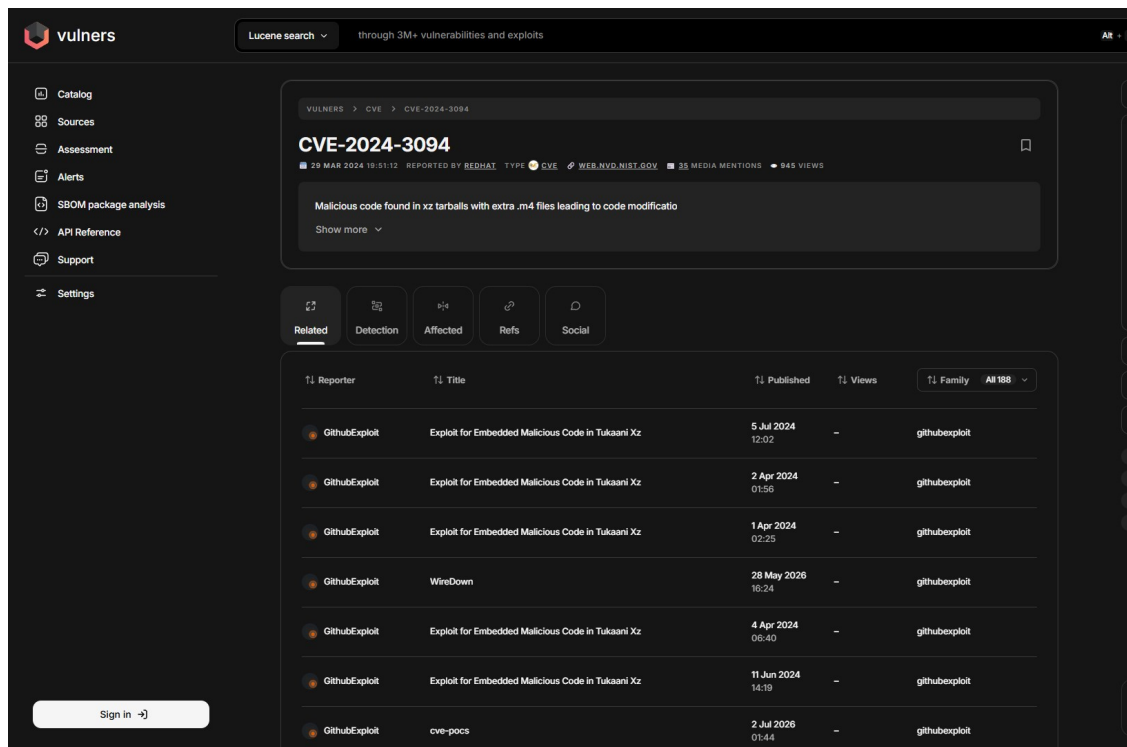


Рисунок 3 – Vulners, карточка CVE

2.4 JVN

JVN — это японская база уведомлений про уязвимости (JPCERT/CC и IPA). Номера там вида JVN# / JNVNU#, в записи описание и часто ссылка на CVE. Много записей по местным продуктам и промышленным системам, в NVD этого иногда просто нет (рисунок 4).

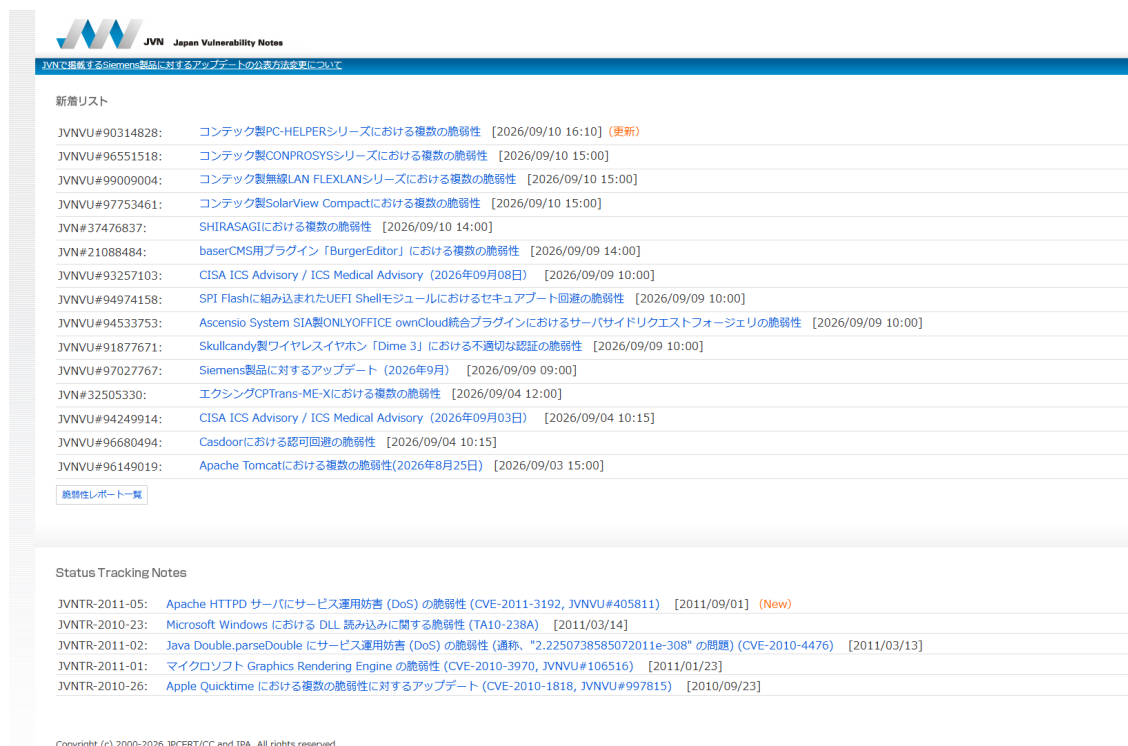


Рисунок 4 – Главная страница JVN

2.5 Exploit-db

Exploit-db — это бесплатный архив эксплоитов и PoC. Их можно открыть и скачать себе, они разбиты по названию, типу (webapps/remote/local/dos) и платформе. На момент лабы в таблице было больше 46 тысяч записей (рисунок 5).

Date	D	A	V	Title	Type	Platform
2026-09-03				FreePBX 17.0.2 - Remote Code Execution (RCE)	WebApps	Multiple
2026-09-03				Metabase 0.61.0 - Authenticated Remote Code Execution	WebApps	Multiple
2026-09-02				EVerest 2025.9.0 - DoS	DoS	Multiple
2026-09-02				Bludit CMS 3.20.0 - Reflected Cross-Site Scripting	WebApps	Multiple
2026-09-02				PodcastGenerator 3.2.9 - Stored XSS	WebApps	Multiple
2026-09-02				Ghost_CMS 6.19.0 - Remote Code Execution	WebApps	Multiple
2026-09-02				Langflow 1.10.0 - RCE	WebApps	Multiple
2026-09-02				Fullhan FH8626V100 - Multiple Vulnerabilities		Multiple
2026-09-02				Marimo 0.20.4 - RCE	WebApps	Multiple
2026-09-01				Wolf CMS 0.8.3.1 - RCE v	WebApps	Multiple
2026-09-01				Payload CMS 3.72.0 - Blind SQL Injection	WebApps	Multiple
2026-09-01				Bludit CMS - Stored XSS	WebApps	Multiple
2026-09-01				Grav CMS 2.0.7 - RCE	WebApps	Multiple
2026-09-01				miniOrange 5.4.3 - Unauthenticated Auth Bypass	WebApps	Multiple
2026-09-01				EasyAppointments 1.5.1 - Blind SQL Injection	WebApps	Multiple

Showing 1 to 15 of 46,687 entries

FIRST PREVIOUS 1 2 3 4 5

Databases	Links	Sites	Solutions
Exploits	Search Exploit-DB	OffSec	Courses and Certifications
Google Hacking	Submit Entry	Kali Linux	Learn Subscriptions

Рисунок 5 – страница Exploit-db

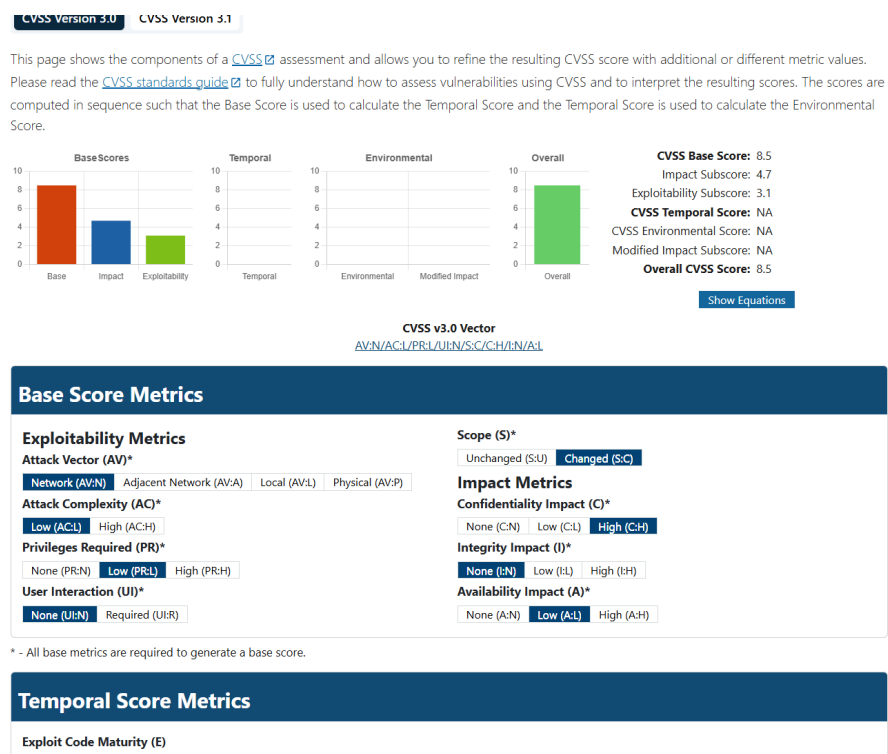
3 ОЦЕНКА УЯЗВИМОСТИ КАЛЬКУЛЯТОРОМ CVSS

Оценка уязвимости калькулятором CVSS с использованием различных метрик и отличия CVSS 3.1 от CVSS 4.0.

3.1 Оценка по базовым метрикам

Задача г) атака низкой сложности будет проводится на сетевой уровень системы, при этом оказывается влияние на другие компоненты системы. Атака приводит к нарушению конфиденциальности высокого уровня и доступности низкого уровня. Взаимодействие с пользователем не требуется, а уровень привилегий — низкий.

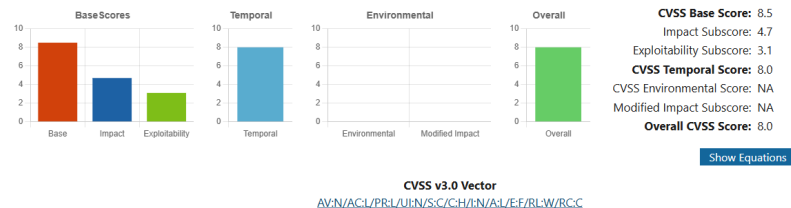
Базовая оценка (BS) — 8.5 (рисунок 6).



Common Vulnerability Scoring System Calculator

CVSS Version 3.0 CVSS Version 3.1

This page shows the components of a [CVSS](#) assessment and allows you to refine the resulting CVSS score with additional or different metric values. Please read the [CVSS standards guide](#) to fully understand how to assess vulnerabilities using CVSS and to interpret the resulting scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.



Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) Adjacent Network (AV:A) Local (AV:L) Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) High (AC:H)

Privileges Required (PR)*

None (PR:N) Low (PR:L) High (PR:H)

User Interaction (UI)*

None (UI:N) Required (UI:R)

Scope (S)*

Unchanged (S:U) Changed (S:C)

Impact Metrics

Confidentiality Impact (C)*

None (C:N) Low (C:L) High (C:H)

Integrity Impact (I)*

None (I:N) Low (I:L) High (I:H)

Availability Impact (A)*

None (A:N) Low (A:L) High (A:H)

* - All base metrics are required to generate a base score.

Рисунок 7 – Калькулятор временных метрик CVSS 3.0

3.3 Оценка по контекстным метрикам

Задача в) К уровню обеспечения КЦД заданы высокие требования, влияние на них также оказывается высоким. При этом проводится атака низкой сложности на локальный уровень системы. Уровень привилегий в данном случае — высокий, взаимодействия с пользователем не происходит. Оказывается ли влияние на другие компоненты системы — неизвестно.

Контекстная оценка (ES) — 7.8 (рисунок 8).

Common Vulnerability Scoring System Calculator

CVSS Version 3.0 CVSS Version 3.1

This page shows the components of a [CVSS](#) assessment and allows you to refine the resulting CVSS score with additional or different metric values. Please read the [CVSS standards guide](#) to fully understand how to assess vulnerabilities using CVSS and to interpret the resulting scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.

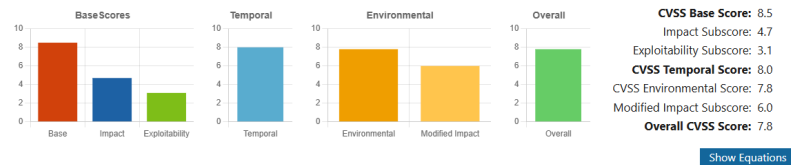


Рисунок 8 – Калькулятор контекстных метрик CVSS 3.0

3.4 Отличия CVSS 3.1 от CVSS 4.0

- появились новые обозначения CVSS-B, CVSS-BT, CVSS-BE, CVSS-BTE, по ним понятно какие группы метрик использовали;
- новая базовая метрика «Требования к Атаке (AT)», она как будто делит старую сложность атаки на две;
- у «Взаимодействие с пользователем (UI)» теперь три значения: None (N), Active (A), Passive (P);
- метрику «Область применения (S)» убрали, вместо неё два набора: влияние на систему и влияние на следующую систему;
- «Временные метрики» переименовали в «Метрики угроз». Убрали «Уровень исправления» и «Достоверность отчёта». Значения High и Functional объединили в Attacked;
- добавили «Дополнительную группу метрик» (Безопасность, Возможность автоматизации, Восстановление, Контроль над ресурсами, Усилия по реагированию, Срочность устранения).

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы были решены следующие задачи:

- проанализированы пять выбранных баз данных угроз и уязвимостей и каждой дано развёрнутое описание;
- проведена работа с калькулятором CVSS, выполнена оценка уязвимостей по трём группам метрик: базовым, временным и контекстным;
- выяснено, в чём отличие CVSS 4.0, от предыдущих метрик.

В ходе лабораторной работы №1 я посмотрел 5 разных БДУ, разобрался чем они отличаются и где их можно применять. Посчитал оценки в калькуляторе CVSS 3.0 по всем 3 группам метрик. Прочитал чем CVSS 3.1 отличается от CVSS 4.0.

Таким образом, все поставленные задачи решены. Цель работы успешно достигнута.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Positive Technologies. Базы данных уязвимостей // Хабр. URL: <https://habr.com/ru/company/pt/blog/266485/>.
2. IC-DV. Базы уязвимостей // Хабр. URL: <https://habr.com/ru/company/ic-dv/blog/453756/>.
3. Хакер. Базы уязвимостей. URL: <https://hacker.ru/2009/05/15/48221/>.
4. Хакер. Как устроены базы уязвимостей // Хабр. URL: <https://habr.com/ru/company/hacker/blog/305262/>.
5. Tom Hunter. Обзор баз уязвимостей // Хабр. URL: <https://habr.com/ru/companies/tomhunter/articles/754812/>.